

NARRATIVA EXPLICATIVA

GQM + PRAGMATIC aplicado al Marco LINDDUN/LIINE4DU

El arte de medir lo que importa en privacidad • España 2025–2026

"En el principio fue la métrica. Y la métrica estuvo con el auditor. Y la métrica era el auditor. Pero el problema es que no todas las métricas son iguales: algunas iluminan, otras entorpecen, y la mayoría simplemente dan trabajo a quien las recoge sin beneficiar a quien las necesita."

CAPÍTULO I — POR QUÉ NECESITAMOS MEDIR LA PRIVACIDAD (Y NO SOLO DECLARARLA)

España tiene el dudoso honor de encabezar regularmente el ranking europeo de infracciones a la normativa de privacidad, con más de 2.700 notificaciones de brechas de datos recibidas por la AEPD solo en 2025. Este dato podría interpretarse de dos formas diametralmente opuestas: que las organizaciones españolas son especialmente incumplidoras, o que la AEPD es especialmente activa en la supervisión y que el ecosistema de cumplimiento está madurando. Probablemente ambas interpretaciones sean parcialmente ciertas.

Lo que resulta indiscutible es que existe una brecha persistente entre el *cumplimiento declarativo* — tener una política de privacidad en la web, haber firmado los contratos de encargado del tratamiento, haber designado un DPO— y el *cumplimiento efectivo*: saber en tiempo real cuántos cuasi-identificadores no controlados existen en los sistemas de datos, qué porcentaje de los consentimientos recabados cumplen realmente los cuatro requisitos del Art. 7 RGPD, o si las brechas de datos se notifican sistemáticamente en menos de 72 horas.

La diferencia entre ambos tipos de cumplimiento es exactamente la diferencia entre un mapa y el territorio. Un mapa dibujado en 2020 no refleja las carreteras que se han construido desde entonces. Una política de privacidad aprobada hace tres años no refleja los doscientos nuevos proveedores de IA que la organización ha incorporado desde que ChatGPT cambió el mundo en noviembre de 2022. Y sin métricas actualizadas, la organización vive felizmente en el mapa mientras el territorio ha cambiado bajo sus pies.

GQM y PRAGMATIC son, en este sentido, la diferencia entre poseer un GPS en tiempo real y tener un atlas de carreteras de la biblioteca municipal.

CAPÍTULO II — GQM: EL ARTE DE HACERSE LAS PREGUNTAS CORRECTAS

El método *Goal–Question–Metric* tiene una virtud que lo distingue de cualquier checklist normativo: obliga a justificar por qué se mide algo antes de decidir qué se mide. Este orden jerárquico —primero el objetivo, luego la pregunta, finalmente la métrica— parece trivial hasta que uno intenta aplicarlo en una organización real.

Imaginemos a una organización mediana del sector financiero que ha decidido "medir su nivel de cumplimiento del RGPD". Sin GQM, lo más probable es que produzca una lista de cien ítems de un checklist descargado de internet, asigne un semáforo verde/amarillo/rojo a cada uno y presente el resultado al Consejo de Administración como "cumplimiento: 73%". Esta cifra no le dice al Consejo nada útil: no sabe si el 27% restante incluye obligaciones de \$10€ de coste o de \$10M€ de multa potencial; no sabe si el 73% de cumplimiento se refiere a documentos existentes o a controles operativos efectivos; y no sabe si la situación mejora o empeora respecto al año anterior.

Con GQM, el proceso se invierte: el Consejo define el *objetivo* ("reducir la exposición regulatoria bajo el RGPD en un 40% en 18 meses"), el DPO formula las *preguntas* que caracterizan ese objetivo ("¿qué porcentaje de nuestros tratamientos de alto riesgo tienen EIPD válida?", "¿en cuánto tiempo respondemos a las brechas de datos?"), y solo entonces se seleccionan las *métricas* que responden a esas preguntas con datos verificables.

El resultado es un sistema de medición trazable desde la estrategia corporativa hasta el dato técnico más granular: cada número tiene un propósito, cada propósito tiene un responsable, y cada responsable sabe exactamente qué hacer cuando el número cambia.

CAPÍTULO III — PRAGMATIC: EL TRIBUNAL DE CALIDAD DE LAS MÉTRICAS

Si GQM responde a la pregunta "¿qué debemos medir?", PRAGMATIC responde a la pregunta quizás más incómoda: "¿vale la pena medirlo así?"

El acrónimo que compone la herramienta —Predictivo, Relevante, Accionable, Genuino, Meaningful (Significativo), Accurate (Preciso), Timely (Oportuno), Independiente, Cheap (Rentable)— fue desarrollado por W. Krag Brotby y Gary Hinson en su obra *PRAGMATIC Security Metrics* (CRC Press, 2013) como respuesta a un problema endémico en el ámbito de la seguridad de la información: la proliferación de métricas que se recogen porque son fáciles de recoger, no porque sean útiles para decidir.

La anécdota fundacional del libro es perfectamente española en su ironía: una empresa de telecomunicaciones americana presentaba cada trimestre al Comité de Seguridad un informe con 847 métricas. Nadie las leía en su totalidad. El comité tomaba sus decisiones basándose en tres o cuatro indicadores que "le decían algo". Las otras 843 métricas existían para demostrar que el departamento de seguridad "estaba haciendo cosas". Este teatro de la medición tiene un coste directo (el tiempo de quienes las recogen y procesan) y un coste de oportunidad (las decisiones que se toman sin la información correcta).

PRAGMATIC resuelve este problema sometiéndolo cada métrica candidata a un tribunal de nueve jueces. Un juez pregunta si la métrica predice algo antes de que ocurra, o solo constata lo que ya ha pasado. Otro juez interroga si el resultado orientará una acción concreta o simplemente se archivará en el informe trimestral. Un tercer juez, con cierta insolencia, pregunta si la métrica mide realmente lo que dice medir, o si es un proxy tan lejano del fenómeno que su relación con la realidad es más filosófica que operativa.

El criterio más políticamente incómodo es quizás el de la Independencia: ¿puede el sujeto medido manipular conscientemente la métrica para mostrar un resultado favorable? Si la respuesta es sí, la métrica tiene el problema fundamental de que incentiva el comportamiento que pretende medir en lugar de medir el comportamiento que pretende incentivar. En el ámbito de la privacidad, este riesgo es particularmente relevante: el porcentaje de EIPDs "completadas" puede inflarse produciendo documentos de mala calidad que cumplen el requisito formal sin evaluar realmente el riesgo.

CAPÍTULO IV — LA INTEGRACIÓN GQM+PRAGMATIC: MAYOR QUE LA SUMA DE SUS PARTES

La verdadera potencia del marco integrado GQM+PRAGMATIC emerge en la sinergia entre ambas metodologías: GQM garantiza la *pertinencia* de las métricas (miden lo que importa), mientras PRAGMATIC garantiza su *calidad* (merecen ser medidas así).

En la práctica, la secuencia es la siguiente:

Paso 1 — Definición de objetivos (GQM nivel 1): La Alta Dirección, asesorada por el DPO y el CISO, define los objetivos estratégicos de privacidad alineados con el marco regulatorio. Para España en 2026, estos objetivos están necesariamente ligados al RGPD, el AI Act, la NIS2 y el ENS.

Paso 2 — Formulación de preguntas (GQM nivel 2): El DPO descompone cada objetivo en preguntas que caracterizan el objeto de medición. Este paso requiere conocimiento técnico y regulatorio simultáneo: no es suficiente con formular preguntas normativas ("¿cumplimos el Art. 35 RGPD?"), sino que es necesario formular preguntas operativas ("¿qué porcentaje de nuestros modelos de ML en producción tienen una EIPD que evalúa el riesgo de linking?").

Paso 3 — Selección de métricas candidatas (GQM nivel 3): Para cada pregunta se proponen una o más métricas candidatas con su fórmula, unidad, fuente de datos y frecuencia.

Paso 4 — Evaluación PRAGMATIC de cada candidata: Cada métrica candidata se somete a la evaluación de los nueve criterios. Se retienen solo las métricas con puntuación ≥ 6.5 (buena) o ≥ 8.0 (excelente). Las métricas con puntuación < 5.0 se descartan o rediseñan.

Paso 5 — Construcción del cuadro de mando (Privacy Dashboard): Las métricas aprobadas se organizan en un cuadro de mando con frecuencia de actualización, responsable, umbral de alerta y acción correctora asociada.

Paso 6 — Revisión periódica (GQM+PRAGMATIC audit): Anualmente se revisa si los objetivos siguen siendo relevantes (el entorno normativo cambia), si las preguntas siguen caracterizando adecuadamente esos objetivos, y si las métricas siguen siendo válidas (nuevas tecnologías pueden hacer obsoletas métricas anteriores o habilitar métricas nuevas).

CAPÍTULO V — EL CASO ESPAÑOL: ENTRE EL MAPA Y EL TERRITORIO

España presenta un perfil de madurez en privacidad que podríamos calificar de *bifurcado*: un pequeño número de organizaciones grandes —principalmente del sector financiero, telecomunicaciones y

algunas administraciones públicas— han alcanzado niveles de madurez equivalentes a los mejores estándares europeos; mientras que la inmensa mayoría del tejido empresarial español, dominado por PYME, se encuentra en un estadio de cumplimiento formal sin profundidad operativa.

El caso paradigmático de 2025 fue la sanción de 10,04 millones de euros impuesta a AENA por un tratamiento de datos biométricos sin EIPD válida. Lo más revelador de este caso no es la cuantía de la sanción —aunque ciertamente concentró la atención de los Consejos de Administración de medio país—, sino la naturaleza del incumplimiento: no fue un hackeo sofisticado, no fue un fallo técnico imprevisible, no fue una laguna jurídica desconocida. Fue la ausencia de un proceso de evaluación de impacto que la normativa lleva exigiendo desde mayo de 2018. Siete años de obligación normativa incumplida.

GQM+PRAGMATIC, aplicado con rigor, habría detectado este problema en el Paso 3: la métrica NC-M2 ("% de tratamientos de alto riesgo con EIPD válida") es una de las métricas con mayor puntuación PRAGMATIC del catálogo (8.67), y su umbral es 100% sin excepciones. Una organización que mide esta métrica trimestral y genuinamente no puede llegar a 2025 sin EIPD en un sistema de reconocimiento facial a escala nacional.

Esto es exactamente lo que distingue el *cumplimiento como destino* del *cumplimiento como proceso*: el primero se declara una vez y se archiva; el segundo se mide continuamente y se mejora.

CAPÍTULO VI — EL AI ACT Y EL NUEVO HORIZONTE DE LAS MÉTRICAS DE IA

El AI Act ha introducido una categoría de métricas que hasta 2025 no existía en ningún framework de cumplimiento: las métricas de *equidad algorítmica*. El Disparate Impact Ratio (DIR), la tasa de errores diferenciales entre grupos protegidos, el ϵ de privacidad diferencial: estas son métricas que no existían en el repertorio del DPO hace tres años, y que hoy son obligatorias para cualquier organización que use sistemas de IA de alto riesgo.

La dificultad de estas métricas no es técnica —los métodos estadísticos existen desde los años 70— sino organizacional: requieren que el equipo de datos, el DPO, el equipo legal y la Alta Dirección hablen el mismo idioma. Un epsilon de privacidad diferencial $\epsilon = 3.7$ es absolutamente opaco para un consejero delegado. Pero "el 98.6% de las personas que interactúan con nuestro modelo de contratación permanecen indistinguibles de otras personas con el mismo perfil" es comprensible para cualquiera.

Este es, precisamente, el trabajo de la columna M (Meaningful/Significativo) en la evaluación PRAGMATIC: no basta con que la métrica sea técnicamente correcta; debe ser comunicable. Las métricas de IA obtenían puntuaciones notablemente bajas en el criterio M en la evaluación del catálogo. Este no es un fallo de las métricas sino una oportunidad de diseño: cada métrica técnica de IA necesita un "gemelo comunicativo" en lenguaje de negocio.

CAPÍTULO VII — EPÍLOGO: LA PRIVACIDAD COMO PRÁCTICA, NO COMO PERFORMANCE

Hay una tensión fundamental en el campo de la privacidad que ningún framework puede resolver completamente: la tensión entre la privacidad como obligación regulatoria —que invita al cumplimiento mínimo, a la métrica de bajo coste y a la EIPD de copia-pega— y la privacidad como valor organizacional —que invita a la excelencia, a la métrica genuina y a la EIPD que realmente evalúa el riesgo.

GQM+PRAGMATIC no puede forzar a una organización a elegir el segundo camino. Lo que sí puede hacer es hacer visible la diferencia entre ambos caminos y hacer explícito el coste real de cada uno. Una métrica con puntuación PRAGMATIC de 9.0 —como la tasa de brechas notificadas en ≤ 72 horas— es incómoda precisamente porque no permite el teatro del cumplimiento: o se notifica en 72 horas o no se notifica. No hay un "más o menos". No hay un "hemos completado el proceso de notificación pendiente de validación final". Hay un timestamp y hay una obligación legal.

Este es el valor último del marco integrado GQM+PRAGMATIC: convertir la privacidad en una práctica medible, honesta y mejora continuamente. No para demostrar a la AEPD que se ha cumplido, sino para saber, de verdad, que se ha cumplido. Y para saber, de verdad, qué hay que mejorar mañana.

Porque al final del día, como advertía el estadístico George Box con su máxima más citada: "*Todos los modelos son incorrectos, pero algunos son útiles.*" Las métricas de privacidad no son la privacidad. Son el mapa. Pero un buen mapa, actualizado, medido con rigor y comunicado con claridad, puede salvar organizaciones enteras del territorio desconocido que es el incumplimiento en la era de la inteligencia artificial.

Narrativa elaborada sobre las bases teóricas de Basili, Caldera & Rombach (1994), Brotby & Hinson (2013), el marco LINDDUN de KU Leuven/DistriNet, LIINE4DU 1.0 de la AEPD y el contexto regulatorio europeo y español vigente en abril de 2026. Versión 1.0.